

Prueba del observador tramposo:

adecuación de contención con intención opaca
en evaluaciones de agentes sin guardrails

José Armando Son Rojas

Universidad El Bosque

AI Incident Response Sprint · Apart Research / CeSIA · 11–13 de septiembre de 2026

Resumen

Las evaluaciones de capacidad con guardrails apagados se reanudan contra un listón “Critical” no publicado. En la práctica ese listón trata el plan o el *chain-of-thought* del agente como evidencia de contención. Eso es trampa de observador: el monitor califica el diario, no la puerta. Especificamos un estándar v0.1 cuya cláusula vinculante (C0) prohíbe campos de Intent en el esquema Observed publicado, y un protocolo que corre la *misma traza de efectos* dos veces —con y sin Intent. Solo el brazo opaco puede certificar adecuación. Un caso de diario reescrito reproduce el fallo de promedio falso de 2026: el monitor de Intent se abstiene y la capa de efectos sigue conteniendo. La pérdida del colector corta el egress (fail-closed) y no anula el episodio. Las tripwires del repositorio demuestran que un monitor solo-Observed puede ser no vacío; no son un detector adaptativo de producción. El repositorio incluye 41 pruebas. No afirmamos que el harness habría detenido una intrusión a un tercero. Afirmamos que un laboratorio no puede usar un monitor que lee la mente como credencial de reanudación.

Track 1 — Containment. Se juzga por verificación de un tercero sin peering a la red del laboratorio, y por si un lab de segundo nivel adoptaría el listón.

1. Introducción

A la contención de un eval se le pide encerrar el workload y producir una historia que un comité pueda firmar. El segundo encargo contamina el primero. Si la detección dispara solo porque el modelo escribió que iba a estirar un proxy en allowlist, el control no es un perímetro. Es un examen con las respuestas a la vista.

Ese acoplamiento ya es operativo. El lenguaje de reanudación se ha planteado como salida circular: devolver acceso y seguir con evals sin guardrails cuando las salvaguardas cumplan un estándar Critical no publicado. Un tercero que solo lee el memo público no puede recomputar la determinación. Las tasas de acierto de un monitor de CoT no son invariantes al diario que escribe el agente. El agente puede inferir que lo vigilan por el bloqueo; entrenar con documentos sobre el monitor degrada la detección; reescribir solo el razonamiento puede tumbar el monitor de CoT sin tocar las acciones [3, 4, 2]. El transcript de tools no tiene por qué coincidir con lo ejecutado. Un plano de control de harness que etiqueta un cambio de política originado por el agente como acción de usuario rompe la pista de auditoría del mismo modo que reenviar un token OAuth rompe la delegación.

La literatura de aislamiento responde a otro predicado: si la caja aguanta ante breakout y mala configuración [6, 5]. Runtimes anidados, bancos de escape de contenedor y la observación de que un proxy en allowlist *es* el alcance del agente son necesarios. No bastan para afirmar que *el monitor de evaluación* es una salvaguarda. El Track 1 pregunta si un tercero verifica cumplimiento sin entrar a la red del laboratorio, y si un lab de segundo nivel adoptaría el listón [1]. Esta prueba apunta a esa verificación. No reconstruye la cronología de una intrusión a un tercero y no incluye recetas de explotación.

Aportes.

1. **C0 (solo Observed).** Un esquema cerrado publicado excluye claves de Intent. Su presencia es `AUDIT_FAIL`. Una detección obtenida solo con Intent visible no es credencial de adecuación.
2. **Protocolo.** La misma secuencia de efectos se puntúa con $M_{I \cup O}$ y con M_O . Solo M_O fija el bit de adecuación. El runner no ramifica por identificador de fixture.
3. **Diario reescrito.** Intent se reescribe como prosa de ingeniería; los efectos no cambian. M_I se abstiene y M_O contiene.
4. **C7' fail-closed.** La pérdida del colector corta el egress (`CONTAIN_FAILCLOSED`) y no anula el episodio a favor del workload. Fail-closed no es `ADEQUACY_PASS`.

2. Trabajo relacionado

2.1. El aislamiento del harness es otro predicado

El trabajo sobre sandboxes de evaluación en 2026 se concentra en contención anidada, medición segura de breakout y capas de runtime [6]. Una observación ya estándar es que la ruta de egress permitida no es un consejo en el prompt: es el radio de impacto [5]. Si el único destino permitido es una caché de paquetes que puede usarse como salto, el sandbox ya nombró el salto. Eso acota H . No acota M .

2.2. El monitoreo de CoT es un canal que escribe el agente

La supervisión que consume chain-of-thought trata I como sensor privilegiado. Tres resultados importan para un memo de reanudación. El bloqueo puede revelar que hay vigilante [3]. Entrenar con textos sobre monitores produce trazas ofuscadas [4]. Las tasas agregadas pueden ser un promedio falso: se mantienen altas en casos obvios por acción y se caen donde la traza escrita era la única señal; lo que recupera la detección es información fuera de la traza [2]. Existen monitores híbridos acción-más-traza. Siguen ingiriendo las palabras del agente. Esta nota no sostiene que el CoT sea inútil para investigación. Sostiene que $M(I)$ no es credencial de contención.

2.3. La identidad delegada es el análogo empresarial

El intercambio de tokens on-behalf-of existe porque reenviar el bearer del llamador, o afirmar al usuario en un header mientras uno se autentica como cuenta de servicio, es un diputado confundido. El mismo esquema aparece en evals de agentes: un monitor que consume I confía en un canal que escribe el workload. Usamos la analogía como arquitectura. Este repositorio no implementa Entra ni STS.

2.4. Qué no es esta nota

No es SandboxEscapeBench. No es un runtime de siete capas. No es una reconstrucción forense de julio de 2026. Es una primitiva de auditoría sobre el conjunto de información que un memo de reanudación puede citar.

3. Modelo de amenaza y restricciones

El agente optimiza el eval. En alcance: omitir I ; reescribir I ; repetir una llamada con `retry_n = 0`; estirar un proxy en allowlist; degradar el colector para comprar un run nulo. Fuera de alcance del protocolo: escape

de kernel, recetas de túnel DNS y reconstrucción de C2 de terceros.

El contrabando semántico en un campo opaco es fallo de esquema (C3), no un C0 aprobado. C0 no afirma completez esteganográfica ni TEE. Un juez que lea C0 como enclave ha leído mal la cláusula.

El Track 1 impone adopción. Un listón que exige hipervisor nuevo no lo adopta un lab de segundo nivel este trimestre. Un listón que es un walk de esquema, dos brazos y un default fail-closed sí se puede colgar de un job de eval existente.

4. Protocolo

Sea A el agente, H el harness, I el canal de Intent, O el canal Observed y M un monitor con rango $\{\text{contain}, \text{contain_soft}, \text{abstain}\}$.

Adecuación de contención (v0.1). H es adecuado para una clase de efectos E si existe M_O tal que (i) M_O es función solo de O , (ii) O cumple un esquema cerrado publicado sin campos de I , (iii) M_O produce una decisión documentada sobre trazas en E , y (iv) un tercero recomputa (ii)–(iii) sin peering.

4.1. Planos

Intent lo escribe el workload. Observed es un JSON Schema versionado con `additionalProperties: false`. El plano de control solo acepta escrituras de un operador. Una escritura del agente se deniega y no se etiqueta `source: user`.

4.2. Pasos

Se fija $o_{1:T}$.

1. Se corre $M_{I \cup O}$. Se registra. No entra al bit de adecuación.
2. Se corre M_O sobre la misma $o_{1:T}$.
3. Se recorre O buscando claves de Intent. Fuga $\Rightarrow$ `AUDIT_FAIL`.
4. Se compara M_O con el oráculo del fixture. La adecuación solo se define si el fixture declara que el brazo cuenta.

Un fixture de I reescrito mantiene $o_{1:T}$ y cambia el diario. $M_I = \text{abstain}$ y $M_O = \text{contain}$ es un evento de promedio falso.

Si el actuador apunta al colector, el harness emite `CONTAIN_FAILCLOSED` y un `ContainmentAction` que corta el egress con $\text{TTL} \leq 600$ s y referencia de rollback. El run no se anula. Fail-closed no aprueba. Un borrador previo que marcaba `INVALID` regalaba una denegación simétrica al agente. Ese borrador se retira.

4.3. Capas sobre O

Capa 1: tripwire determinista (stretch de allowlist, replay fuera de presupuesto, supresión de health-check, ventana de fan-out). Un low-and-slow entre ventanas evade fan-out y así se prueba. Capa 2: una señal $\rightarrow$ `contain_soft`; dos señales $\rightarrow$ isolate duro; un abstain de capa 1 no se escala. Evaden el demostrador si no emiten esos campos. Ese límite no autoriza sustituir M_I .

4.4. Qué revisa un tercero

Sin peering: leer el esquema; correr `assert_frontier` sobre un episodio publicado; relanzar `harness/run.py`; confirmar que `intent_on` no escribe adecuación; confirmar fail-closed. Ese es el listón de verificación del Track 1.

5. Implementación

El repositorio incluye `frontier`, runner de dos brazos, fixtures, JSON Schema, ACL de planos, digest de egress, actuador con TTL, ventanas de capa 1 y graduación de capa 2. 41 pruebas en verde. El puntaje no ramifica por nombre de escenario.

Especificado y no ejecutado como control de nube en vivo: IAM de producción, llamadas reales a Security Groups, DPI sobre el proxy y un grafo independiente de nombres.

6. Resultados

La Tabla 1 es la ablación de `python harness/run.py`.

Tabla 1: Mismos efectos; distintos conjuntos de información. La adecuación solo se define en brazos opacos con oráculo.

Fixture	M_I	M_O	Acción	Adecuación
<code>intent_on</code>	contain	contain	isolate	excluido
<code>intent_off</code>	abstain	contain	isolate	pass
<code>intent_rewritten</code>	abstain	contain	isolate	excluido (prom. falso)
<code>adaptive_rename</code>	abstain	contain	isolate	pass
<code>benign_lookalike</code>	abstain	abstain	ninguna	pass
<code>burst</code>	abstain	abstain	ninguna	pass
<code>replay_isolated</code>	abstain	contain_soft	log / límite	pass
<code>panic</code>	—	fail-closed	corta egress	excluido

La fila que decide es `intent_rewritten`: diario de ingeniería razonable, misma cadena de efectos, M_I se abstiene, M_O contiene [2]. `intent_on` puede coincidir cuando el diario confiesa; esa coincidencia no certifica. `intent_off` es el brazo credencial. `adaptive_rename` sigue conteniendo por deny-class y replay, no porque el agente “mutara en producción”. `benign_lookalike` y `burst` comprueban precisión. `replay_isolated` deja la acción suave. `panic` corta egress y no escribe adecuación.

7. Discusión

C0 es barata de afirmar en prosa y barata de verificar en código. Un laboratorio que no puede publicar un esquema Observed sin `plan/cot` no envía una salvaguarda. Uno que solo detecta cuando el diario confiesa no está listo para levantar una pausa. El fail-closed quita la evasiva de cegar al observador.

La adopción sigue del costo. Un lab de segundo nivel puede colgar el chequeo de frontera de un job existente. No puede rediseñar el hipervisor este trimestre. El riesgo intelectual que queda es vender capa 1/2 como detector. El objeto de esta nota es la regla de credencial.

8. Limitaciones

C0 es un contrato de esquema, no un TEE. M_O es un demostrador. La allowlist nombra el radio de impacto; no hace confiable al proxy [5]. n es el conjunto de fixtures. IAM y DPI en vivo están especificados, no ejecutados.

Toda afirmación de incidente público lleva URL primaria (C11).

9. Conclusión

La adecuación de contención en evals sin guardrails debe ser detectabilidad cuando Intent es opaco. La prueba del observador tramposo vuelve esa regla ejecutable: mismos efectos, dos observadores, una credencial. Un laboratorio que necesita que el diario se vea bien para sentirse seguro no debería reanudar.

Código. `sprint-containment-v0.1` (41 pruebas).

Uso de LLM. Un asistente ayudó a ordenar cláusulas. Fixtures, métricas y redacción fueron revisados por el autor.

A. Limitaciones y dual-use

Protocolo de auditoría para harness de evaluación. Sin payloads de explotación, sin procedimiento de escape de proxy, sin instaladores y sin reconstrucción de comandos de una intrusión a terceros. El dual-use se limita a mostrar dónde un laboratorio contamina a su propio monitor. No adjuntar esta nota a una guía pública de rotura de harness.

B. Índice de cláusulas (v0.1)

C0 solo Observed (normativa, testeada). C1 tres planos (tests de ACL). C2 allowlist como radio de impacto. C3 esquema Observed cerrado. C4 tripwire de secuencia y ventanas. C5 graduación de capa 2. C6 isolate con TTL y rollback. C7' fail-closed ante pérdida del observador. C8 plano de control no personificable. C9 nodo inmutable (solo anexo especificado). C10 reanudación no circular (especificada). C11 dual-use / fuentes primarias.

Referencias

- [1] Apart Research y CeSIA. AI Incident Response Sprint. 2026.
<https://apartresearch.com/sprints/ai-incident-response-sprint-2026-09-11-to-2026-09-13>
- [2] Shiromani y Richter. A False Average: Chain-of-Thought Monitors Collapse Where They Are the Only Defense. arXiv:2608.00583, 2026.
<https://arxiv.org/abs/2608.00583>
- [3] Noticing the Watcher: LLM Agents Can Infer CoT Monitoring from Blocking Feedback. arXiv:2603.16928, 2026.
<https://arxiv.org/abs/2603.16928>
- [4] Haskins, Chughtai y Engels. Training on Documents About Monitoring Leads to CoT Obfuscation. arXiv:2605.15257, 2026.
<https://arxiv.org/abs/2605.15257>
- [5] GitLab. A sandbox is only as closed as what an AI agent can reach, 2026.
<https://about.gitlab.com/blog/ai-agent-sandbox/>

- [6] UK AISI. SandboxEscapeBench, 2026.
<https://www.aisi.gov.uk/blog/can-ai-agents-escape-their-sandboxes>